

The Agency for the Protection of Personal Data has imposed an administrative monetary fine on the data controller – a commercial company for organizing games of chance – betting games (sports betting) in the amount of 380,000.00 euros (2,863,110.00 kuna) due to the following established violations of the General Data Protection Regulation:

1. The data controller processed personal data, specifically copies of the respondents' bank cards, for which no legal basis for processing was demonstrated, thereby violating Article 6, paragraph 1 of the General Data Protection Regulation;
2. The data controller did not adequately inform the respondents about the processing of personal data, specifically regarding the processing of data contained in the copies of bank cards, thereby violating Article 13, paragraphs 1 and 2 of the General Data Protection Regulation;
3. When creating a new business process for the service of quick payouts to VISA bank cards, the data controller did not implement appropriate technical and organizational measures, thereby violating Article 25, paragraphs 1 and 2 of the General Data Protection Regulation;
4. The data controller did not apply the technical measure of encryption to the personal data of respondents stored in the databases of the data controller and did not regularly assess the effectiveness of technical and organizational measures to ensure the security of processing, thereby violating Article 32, paragraph 1, points a) and d) of the General Data Protection Regulation.

Namely, the Agency received a submission from a citizen regarding the collection of mutual copies of bank cards via electronic mail by the aforementioned data controller. In accordance with its powers, the Agency initiated proceedings ex officio due to a high risk to the rights and freedoms of the respondents (players, service users).

In the specific case, it was established that from June to December 2022, the data controller provided players with an additional service for payouts to VISA cards, in addition to the already existing options for withdrawing funds from the user account to a bank account. It was determined that the processing or collection of copies of bank cards was not necessary to comply with legal obligations arising from the Anti-Money Laundering Act, as the due diligence on players could be conducted without collecting mutual copies of bank cards. Consequently, the data controller unlawfully processed copies of bank cards using inadequate processing means and stored them without applying appropriate technical and organizational measures.

Furthermore, the data controller did not inform the respondents about the processing in question (storage of copies of bank cards) in accordance with the principle of transparency, thus depriving the respondents of essential information about data processing such as legal basis, purpose, and storage period. Specifically, in the Statement on Personal Data Protection Measures, which is part of the Privacy Policy, it was explicitly stated that the data controller does not store bank card numbers and that the numbers are not accessible to unauthorized persons.

However, employees of the data controller during the period from June to December 2022 had access to 655 copies of bank cards, on which the full range of data was visible out of a total of 2,078 copies of bank cards collected. Such processing resulted in a high-risk violation of one-third of the total processed data, while the respondents were not even aware that their data was being stored in databases.

Considering that financial data is regarded as a sensitive category of personal data, which depending on the context and scope of processing can pose a high risk to the rights and freedoms of respondents, the data controller was obliged to pay special attention to the security and legality of processing, which was taken into account as an aggravating circumstance.

As a mitigating circumstance in the specific proceedings, the degree of responsibility demonstrated by the data controller after the conducted supervision was noted – on its own initiative, it informed the Agency about how it plans to align processing with the provisions of the General Data Protection Regulation. Thus, the data controller made additional investments in payment processes in such a way

that the system was upgraded and no longer requires the submission of copies of bank cards, and all stored copies of bank cards were deleted. Additionally, the data controller stated that it has improved business processes for monitoring the processing of personal data and has educated its employees.